FICHE 9 - SÉCURISER LES SERVEURS

Renforcer les mesures de sécurité appliquées aux serveurs.

La sécurité des serveurs doit être une priorité car ils centralisent un grand nombre de données et hébergent les services permettant d'y accéder et de les manipuler.

Les précautions élémentaires

- **Désinstaller ou désactiver les services et interfaces inutiles.**
- **Limiter l'accès aux outils et interfaces d'administration aux seules personnes habilitées.** Utiliser des comptes utilisateurs sans privilèges pour les opérations courantes.
- **Adopter une politique spécifique de mots de passe** pour les administrateurs. Changer les mots de passe, au minimum, lors de chaque départ d'un administrateur et en cas de suspicion de compromission.
- **Installer les mises à jour critiques** sans délai (le cas échéant après les avoir testées), en particulier les correctifs de sécurité, que ce soit pour les systèmes d'exploitation ou pour les applications, en programmant une vérification automatique hebdomadaire.
- **Utiliser des logiciels de détection et de suppression de programmes malveillants** (ex. : antivirus) régulièrement mis à jour.
- **Utiliser des comptes nominatifs** pour l'accès aux bases de données et créer des comptes techniques spécifiques à chaque application.
- **Effectuer des sauvegardes et vérifier régulièrement leur intégrité et la capacité de les restaurer** (voir la fiche n°17 - Sauvegarder).
- **Mettre en œuvre le protocole TLS** (en remplacement de SSL[33]), ou un protocole assurant le chiffrement et l'authentification, au minimum pour tout échange de données sur Internet et vérifier sa bonne mise en œuvre par des outils appropriés[34].
- Ne pas autoriser les algorithmes de chiffrement obsolètes dans les communications avec le serveur.
- **Mettre en place un système de journalisation des évènement**s (voir la fiche n°16 - Tracer les opérations).

Ce qu'il ne faut pas faire

- Traiter des données personnelles sur des serveurs obsolètes et ne pas prévoir le remplacement de ces derniers.
- Utiliser des protocoles d'échange de données non sécurisés (ex. : authentification en clair, flux en clair).
- Utiliser les serveurs pour d'autres fonctions que celles auxquelles ils sont dédiés, notamment pour naviguer sur des sites web ou accéder à une messagerie électronique.
- Placer les bases de données sur un serveur directement accessible depuis Internet.
- Utiliser des comptes génériques (c'est-à-dire partagés entre plusieurs utilisateurs).

33 Le protocole TLS est parfois appelé, à tort, SSL ou SSL/TLS. Le protocole SSL, prédécesseur de TLS, est aujourd'hui obsolète et à proscrire.

34 Pour TLS, il existe plusieurs outils à cette fin (ex. : « SSL Server Test », ssllabs.com, « SSL-Tools », ssl-tools.net).